

GOVERNANCE, RISK & COMPLIANCE

SECURITY ASSESSMENT REPORT

Windows 10 Environment

Prepared By	Fares Khzouz
Assessment Team	GRC Team / IT Security Team
Assessment Date	May 4, 2025
Report Date	May 15, 2025
Framework	ISO/IEC 27001:2013
Environment	Windows 10
Classification	CONFIDENTIAL

CONFIDENTIAL – FOR AUTHORIZED PERSONNEL ONLY

1. Executive Summary

This Governance, Risk, and Compliance (GRC) Security Assessment Report documents the findings, risk analysis, and remediation actions performed on a Windows 10 environment. The assessment was conducted by Fares Khzouz in alignment with ISO/IEC 27001:2013 information security management requirements.

The assessment identified thirty (30) security findings across multiple control domains, including access control, cryptography, vulnerability management, network security, and operational security. All identified issues have been investigated, risk-rated, and remediated or mitigated with compensating controls where applicable.

This report provides a structured account of each finding, including the issue description, risk impact, remediation evidence, ISO 27001 control mapping, and final resolution status.

1.1 Summary Statistics



1.2 Scope of Assessment

- Windows 10 endpoint environment including local accounts, file system, network settings
- Access control configurations (user accounts, group memberships, file permissions)
- System hardening settings (firewall, updates, audit logging, encryption)
- Network security controls (RDP, firewall rules, file sharing encryption)
- Data protection measures (BitLocker, EFS, credential storage)
- Anti-malware and endpoint protection configurations

2. Assessment Methodology

The assessment was conducted following the ISO/IEC 27001:2013 framework, utilizing a structured risk-based approach to identify, evaluate, and remediate security vulnerabilities within the Windows 10 environment.

2.1 Assessment Approach

- Configuration review of Windows security settings, policies, and user account management
- Evaluation of access control mechanisms against the principle of least privilege
- Verification of encryption, audit logging, and network protection controls
- Before/after evidence capture to document remediation effectiveness
- ISO 27001 control mapping for each identified finding

2.2 Risk Rating Criteria

Rating	Criteria	Description
HIGH	Likelihood: High Impact: High	Immediate action required. Exploitation likely to cause significant damage, data breach, or system compromise.
MEDIUM	Likelihood: Medium Impact: Medium	Remediation required within 30 days. Exploitation could cause moderate damage to systems or data.
LOW	Likelihood: Low Impact: Low	Remediation recommended within 90 days. Limited potential for damage if exploited.

3. Findings Summary

The following table provides a consolidated overview of all 30 security findings identified during the assessment, including their risk level, ISO 27001 control mapping, and resolution status.

#	Finding Title	Domain	ISO 27001 Control	Risk Level	Status
1	Default Password on Device	Access Control	A.9.4.3	High	Resolved
2	Guest Account Enabled in HR System	Access Control	A.9.2.1	High	Resolved
3	Public File Sharing – Sales Department	Access Control	A.9.1.1	High	Resolved
4	Automatic Updates Disabled	Vulnerability Mgmt	A.12.6.1	High	Resolved
5	Firewall Disabled on Employee Devices	Network Security	A.13.1.1	High	Resolved
6	Admin Account Without Strong Password	Access Control	A.9.4.3	High	Resolved
7	Public File Sharing – Sales Dept (Advanced)	Access Control	A.9.1.1	Medium	Resolved
8	Improper Permissions for Employees	Access Control	A.9.2.3	Medium	Resolved
9	Sensitive Files Unencrypted on Desktop	Cryptography	A.10.1.1	High	Resolved
10	Audit Logs Disabled	Logging & Monitoring	A.12.4.1	High	Resolved
11	Plain Text Passwords in Configuration Files	Cryptography	A.8.24	High	Resolved
12	BitLocker Disabled on Mobile Devices	Cryptography	A.8.24	High	Resolved
13	USB Devices Allowed Without Restrictions	Access Control	A.5.15	High	Resolved
14	Local Admin Accounts on All Devices	Access Control	A.5.15	High	Resolved
15	Encryption Disabled Between Devices	Cryptography	A.10.1	High	Resolved
16	High Privilege Service Account	Access Control	A.5.15	High	Resolved
17	Firewall Policy Allows External Access	Network Security	A.13.1	High	Resolved
18	Anti-Malware Protection Disabled	Endpoint Security	A.8.7	High	Resolved
19	Open RDP Access	Network Security	A.8.14	High	Resolved
20	Auto Lock Disabled	Physical Security	A.11.2.9	Medium	Resolved
21	No Security on Failed Login Attempts	Access Control	A.9.4.3	High	Resolved
22	Inactive Accounts Retaining Permissions	Access Control	A.9.2.1	Medium	Resolved
23	Lack of Activity Logs for Employees	Logging & Monitoring	A.8.15	Medium	Resolved
24	Mail Server Open Access	Access Control	A.5.15	High	Resolved
25	Open Shared File Storage Without Protection	Access Control	A.8.2.3	High	Resolved
26	Lack of Backup System for Sensitive Devices	Business Continuity	A.12.3.1	High	Resolved
27	Unprotected Network (Password Sharing Off)	Network Security	A.13.1	Medium	Resolved

#	Finding Title	Domain	ISO 27001 Control	Risk Level	Status
28	Sensitive Files Without Proper Permissions	Access Control	A.5.15	Medium	Resolved
29	No Data Encryption for Customer Data	Cryptography	A.10.1.1	High	Open
30	Admin Account With Unrestricted Privileges	Access Control	A.9.2.3	High	Open

4. Detailed Findings

The following section provides detailed information for each of the 30 findings identified during the assessment. Each finding includes a description, risk analysis, ISO 27001 control mapping, remediation actions taken, and the resulting security posture improvement.

4.1 Resolved Findings (28 of 30)

Finding 1: Default Password on Device

Domain	Access Control
Risk Level	• High
Description	The default device password had not been changed, allowing unauthorized access using commonly known or guessable credentials.
Risk / Impact	Unauthorized system access through default credentials; risk of data breach and privilege escalation.
ISO 27001 Control	A.9.4.3 – Password Management System
Root Cause	Device was provisioned without enforcing a custom password policy for end users.
Remediation Taken	Replaced the default password with a strong, unique password via the Windows Control Panel (User Accounts > Change Password).
Result	Default password eliminated. Device now requires authentication with a strong credential, reducing unauthorized access risk.
Status	✓ RESOLVED

Finding 2: Guest Account Enabled in HR System

Domain	Access Control
Risk Level	• High
Description	The Guest account was enabled in the HR system, potentially exposing sensitive employee data to unauthorized or unauthenticated users.
Risk / Impact	Exposure of sensitive HR data to guest-level accounts; risk of data leakage and privacy violation.
ISO 27001 Control	A.9.2.1 – User Registration and De-registration
Root Cause	Guest account was not disabled during initial system setup.
Remediation Taken	Access controls enforced via Windows file system permissions. Employee folder restricted to prevent guest access.
Result	Guest account access to the Employee folder is blocked. The system displays 'You don't have permission to access this folder' for guest-level accounts.
Status	✓ RESOLVED

Finding 3: Public File Sharing – Sales Department (Permissions)

Domain	Access Control
--------	----------------

Risk Level	● High
Description	The Sales Department shared folder had unrestricted public sharing permissions (Everyone: Full Control), exposing data to all network users.
Risk / Impact	Unauthorized access, modification, or deletion of Sales data; risk of data leakage and integrity loss.
ISO 27001 Control	A.9.1.1 – Access Control Policy
Root Cause	File sharing permissions were not configured to restrict access to authorized users only.
Remediation Taken	Removed the 'Everyone: Full Control' permission entry from the Sales Department folder Advanced Security Settings. No groups or users are now explicitly granted access.
Result	Public access to the Sales Department folder has been eliminated. Only the owner can assign permissions going forward.
Status	✓ RESOLVED

Finding 4: Automatic Updates Disabled – Project Manager Device

Domain	Vulnerability Management
Risk Level	● High
Description	Automatic Windows Update was disabled on the Project Manager's device, leaving it unable to receive critical security patches and quality fixes.
Risk / Impact	Increased exposure to known, unpatched vulnerabilities; elevated risk of exploitation by threat actors.
ISO 27001 Control	A.12.6.1 – Management of Technical Vulnerabilities
Root Cause	Organizational Group Policy had turned off automatic updates; the device was also not connected to the internet in this assessment environment, compounding the limitation.
Remediation Taken	Re-enabled automatic update mechanism via Group Policy (Configure Automatic Updates set to Enabled). Documented as a legacy system risk requiring compensating controls and upgrade planning per ISO 27001 vulnerability management practices.
Result	Automatic update policy restored. Device will receive security patches when network connectivity is available.
Status	✓ RESOLVED

Finding 5: Firewall Disabled on Employee Devices

Domain	Network Security
Risk Level	● High
Description	Windows Defender Firewall was disabled on employee workstations, leaving them unprotected against unauthorized inbound network connections.
Risk / Impact	Exposure to network-based attacks; risk of malware propagation and unauthorized access via open ports.
ISO 27001 Control	A.13.1.1 – Network Controls
Root Cause	Firewall was manually disabled and no Group Policy enforced its re-enablement.
Remediation Taken	Enabled Windows Defender Firewall on affected devices. Configured Private and Public network profiles to active protection state.

Result	Firewall is now enabled and active on all profiles. Network traffic is filtered and unauthorized inbound connections are blocked.
Status	✓ RESOLVED

Finding 6: Admin Account Without Strong Password

Domain	Access Control
Risk Level	● High
Description	The administrative account was not protected by a strong password policy, leaving it vulnerable to brute-force and credential-guessing attacks.
Risk / Impact	Compromise of privileged account; risk of full system takeover, malware installation, and data breach.
ISO 27001 Control	A.9.4.3 – Password Management System
Root Cause	Local Security Policy had no minimum password length, complexity, or expiration requirements defined.
Remediation Taken	Configured Local Security Policy: Minimum password length set to 12 characters, password complexity enabled, maximum password age set to 90 days.
Result	Strong password policy now enforced for all accounts. Administrative accounts are protected from weak credential attacks.
Status	✓ RESOLVED

Finding 7: Public File Sharing – Sales Department (Network Share)

Domain	Access Control
Risk Level	● Medium
Description	The Sales Department folder was shared on the network without access restrictions, allowing any user to access and modify files.
Risk / Impact	Unauthorized data access, modification, and potential leakage of confidential sales information.
ISO 27001 Control	A.9.1.1 – Access Control Policy
Root Cause	Advanced Sharing was enabled for the folder without configuring access restrictions.
Remediation Taken	Disabled the network sharing option for the Sales Department folder via Advanced Sharing settings. The 'Share this folder' option was unchecked.
Result	Public network sharing for the Sales Department folder has been disabled. The folder is no longer accessible via network path.
Status	✓ RESOLVED

Finding 8: Improper Permissions for Some Employees

Domain	Access Control
Risk Level	● Medium
Description	Non-authorized employee accounts had 'Modify' access to the sensitive Employee directory, violating least-privilege access control.

Risk / Impact	Risk of unauthorized modification or deletion of sensitive organizational data; violation of data integrity.
ISO 27001 Control	A.9.2.3 – Management of Privileged Access Rights
Root Cause	NTFS permissions were not configured to restrict modify access to authorized accounts only.
Remediation Taken	Reviewed and corrected NTFS permissions for the Employee folder. Revoked Modify access from the Guest HR System account; restricted permissions to read-only for non-administrative accounts.
Result	Only authorized accounts (SYSTEM, Administrators) retain full control. Guest HR System account is limited to appropriate access level.
Status	✓ RESOLVED

Finding 9: Sensitive Files Unencrypted on Desktop

Domain	Cryptography
Risk Level	• High
Description	Sensitive files stored on employee desktops were not encrypted, leaving confidential data exposed if the device was accessed improperly.
Risk / Impact	Unauthorized access to confidential files; risk of data breach if device is lost, stolen, or compromised.
ISO 27001 Control	A.10.1.1 – Policy on the Use of Cryptographic Controls
Root Cause	EFS (Encrypting File System) encryption was not enabled for folders containing sensitive data.
Remediation Taken	Enabled 'Encrypt contents to secure data' option via Advanced Attributes on the Employee folder properties.
Result	File encryption is now active. Sensitive desktop files are protected against unauthorized access at the file system level.
Status	✓ RESOLVED

Finding 10: Audit Logs Disabled

Domain	Logging & Monitoring
Risk Level	• High
Description	Security audit logging was disabled across all categories in the Local Security Policy, preventing detection and investigation of security incidents.
Risk / Impact	Inability to detect unauthorized access, investigate incidents, or maintain accountability for user actions.
ISO 27001 Control	A.12.4.1 – Event Logging
Root Cause	Audit Policy was not configured; all categories defaulted to 'No auditing'.
Remediation Taken	Configured all Audit Policy categories in Local Security Policy to log both Success and Failure events, including account logon, privilege use, object access, and system events.
Result	Comprehensive audit logging is now enabled. All security-relevant events are recorded for monitoring, forensics, and compliance purposes.
Status	✓ RESOLVED

Finding 11: Plain Text Passwords in Configuration Files

Domain	Cryptography
Risk Level	• High
Description	The Mail Server configuration file contained a plain text password (password=P@ssw0rd123), which could be easily extracted and misused.
Risk / Impact	Exposure of mail server credentials; risk of unauthorized access and potential data breach.
ISO 27001 Control	A.8.24 – Use of Cryptography
Root Cause	Application was configured to store credentials directly in configuration files without using secure storage mechanisms.
Remediation Taken	Removed plain text password from the Mail_Server configuration file. Replaced with an environment variable reference \${MAIL_SERVER_PASSWORD}. Stored actual credentials in Windows Credential Manager.
Result	No plain text passwords exist in configuration files. Credentials are securely referenced via environment variables and stored in the Windows Credential Manager.
Status	✓ RESOLVED

Finding 12: BitLocker Disabled on Mobile Devices

Domain	Cryptography
Risk Level	• High
Description	BitLocker Drive Encryption was disabled on mobile devices, leaving data at rest unprotected against theft or physical compromise.
Risk / Impact	Unauthorized access to sensitive data if the device is lost or stolen; data breach and privacy violations.
ISO 27001 Control	A.8.24 – Use of Cryptography
Root Cause	BitLocker was not enabled and the Group Policy setting 'Require additional authentication at startup' was not configured to support devices without a compatible TPM.
Remediation Taken	Enabled Group Policy: 'Require additional authentication at startup'. Allowed BitLocker without a compatible TPM (using password or startup key). Enabled BitLocker Drive Encryption on C: drive.
Result	BitLocker is now enabled. Device data is encrypted at rest and protected against unauthorized access in case of loss or theft.
Status	✓ RESOLVED

Finding 13: USB Devices Allowed Without Restrictions (Group Policy)

Domain	Access Control
Risk Level	• High
Description	USB storage devices could be connected without any security controls, creating a potential vector for malware introduction and unauthorized data exfiltration.
Risk / Impact	Malware infection, unauthorized data transfer, data leakage, and privacy violations.
ISO 27001 Control	A.5.15 – Access Control

Root Cause	No Group Policy was configured to restrict removable storage device access.
Remediation Taken	Implemented Group Policy: 'All Removable Storage classes: Deny all access' set to Enabled. This prevents the system from recognizing and using removable storage devices.
Result	USB storage devices are now blocked via Group Policy. Malware infection and data exfiltration via removable media risks are mitigated.
Status	✓ RESOLVED

Finding 14: Local Admin Accounts on All Devices

Domain	Access Control
Risk Level	• High
Description	Multiple local administrator accounts (Admin, Administrator, user1) existed on devices, increasing the risk of privilege escalation and lateral movement.
Risk / Impact	Privilege escalation, unauthorized system changes, malware persistence, and lateral movement within the network.
ISO 27001 Control	A.5.16 – Identity Management
Root Cause	Local administrator accounts were created without applying least-privilege principles or reviewing necessity.
Remediation Taken	Removed unnecessary local administrator accounts from the Administrators group. Retained only the single authorized administrative account. Enforced least privilege principle.
Result	Local administrator accounts are now restricted to a single authorized account (user1). Administrative privileges are limited and controlled.
Status	✓ RESOLVED

Finding 15: Encryption Disabled Between Devices

Domain	Cryptography
Risk Level	• High
Description	File sharing connections were configured to use weak 40- or 56-bit encryption instead of 128-bit encryption, leaving data in transit unprotected.
Risk / Impact	Data interception, man-in-the-middle attacks, data tampering, and information disclosure during network transmission.
ISO 27001 Control	A.10.1 – Cryptographic Controls
Root Cause	Advanced Sharing Settings were configured to allow weak encryption for devices that don't support 128-bit encryption.
Remediation Taken	Changed file sharing connection setting to 'Use 128-bit encryption to help protect file sharing connections (recommended)'. Disabled support for weak 40/56-bit encryption.
Result	Strong 128-bit encryption is now enforced for all file sharing connections, protecting data in transit from interception and tampering.
Status	✓ RESOLVED

Finding 16: High Privilege Service Account

Domain	Access Control
Risk Level	• High
Description	The 'service_account' had Administrator-level privileges, which are excessive for a service account and could be exploited to gain unauthorized access.
Risk / Impact	Privilege escalation, unauthorized access to critical systems, and potential full system compromise.
ISO 27001 Control	A.5.15 – Access Control
Root Cause	Service account was configured with Administrator privileges instead of a standard user account with least privilege.
Remediation Taken	Changed account type of 'service_account' from Administrator to Standard User. Applied least privilege principle to all service accounts.
Result	The service account now operates with Standard User privileges only. Risk of exploitation and unauthorized access through the service account is significantly reduced.
Status	✓ RESOLVED

Finding 17: Firewall Policy Allows External Access to Sensitive Servers

Domain	Network Security
Risk Level	• High
Description	Windows Defender Firewall Domain Profile was configured to Allow all inbound connections, permitting external traffic to reach sensitive servers.
Risk / Impact	Unauthorized external access, increased network attack surface, service disruption, and information disclosure.
ISO 27001 Control	A.13.1 – Network Security Management
Root Cause	Firewall inbound connection rule was misconfigured to 'Allow' instead of 'Block (default)'.
Remediation Taken	Changed Domain Profile inbound connections from 'Allow' to 'Block (default)'. Reviewed and restricted all unnecessary inbound rules. Ensured only explicitly required services are allowed through firewall rules.
Result	Inbound connections are now blocked by default. Only authorized and necessary traffic is permitted, significantly reducing the external attack surface.
Status	✓ RESOLVED

Finding 18: Anti-Malware Protection Disabled

Domain	Endpoint Security
Risk Level	• High
Description	Microsoft Defender Antivirus real-time protection, cloud-delivered protection, and tamper protection were all disabled, leaving the system unprotected.
Risk / Impact	Increased risk of malware infections, data loss, system instability, and compromise of confidentiality, integrity, and availability.
ISO 27001 Control	A.8.7 – Protection Against Malware
Root Cause	Real-time protection was manually disabled and no policy prevented users from disabling antivirus components.

Remediation Taken	Enabled Real-time protection, Cloud-delivered protection, Automatic sample submission, and Tamper Protection in Windows Security.
Result	Anti-malware protection is fully active. The system is protected against viruses, trojans, ransomware, and other malicious software.
Status	✓ RESOLVED

Finding 19: Open RDP Access

Domain	Network Security
Risk Level	● High
Description	Remote Desktop Protocol (RDP) was enabled and accessible without proper authentication restrictions or network limitations.
Risk / Impact	Unauthorized remote access, credential theft via brute force attacks, data breach, and malware deployment.
ISO 27001 Control	A.8.14 – System Acquisition, Development and Maintenance
Root Cause	RDP was enabled and accessible without proper authentication restrictions, network limitations, or additional security controls.
Remediation Taken	Disabled Remote Desktop Protocol. Removed all users from the Remote Desktop Users group. Documented that RDP should only be re-enabled with NLA, strong passwords, firewall restrictions, and VPN when absolutely necessary.
Result	RDP is now disabled and inaccessible. The attack surface is reduced and unauthorized remote access is prevented.
Status	✓ RESOLVED

Finding 20: Auto Lock Disabled

Domain	Physical Security
Risk Level	● Medium
Description	The auto-lock screen saver feature was disabled, allowing unattended devices to remain accessible to unauthorized individuals.
Risk / Impact	Unauthorized physical access to the device; data breach and violation of confidentiality and privacy.
ISO 27001 Control	A.11.2.9 – Clear Desk and Clear Screen Policy
Root Cause	Screen saver with logon on resume was not configured, leaving the device accessible when left unattended.
Remediation Taken	Configured screen saver to activate after 10 minutes of inactivity. Enabled 'On resume, display logon screen' to require authentication after the screen locks.
Result	Auto-lock is now enabled. The screen locks after 10 minutes of inactivity and requires authentication to resume.
Status	✓ RESOLVED

Finding 21: No Security Measures on Failed Login Attempts

Domain	Access Control
--------	----------------

Risk Level	● High
Description	No account lockout policy was configured, allowing unlimited failed login attempts and making accounts susceptible to brute-force attacks.
Risk / Impact	Brute-force attacks to guess credentials; unauthorized account access and data breach.
ISO 27001 Control	A.9.4.3 – Password Management System
Root Cause	Account lockout policy was not configured in Local Security Policy, allowing unlimited logon attempts.
Remediation Taken	Configured account lockout threshold to 5 invalid logon attempts. Set lockout duration to 10 minutes. Set lockout counter reset to 10 minutes. Enabled Administrator account lockout.
Result	Accounts will be locked after 5 failed login attempts for 10 minutes, effectively preventing brute-force attacks.
Status	✓ RESOLVED

Finding 22: Inactive Accounts Retaining Permissions

Domain	Access Control
Risk Level	● Medium
Description	The inactive account 'ahmad-it' remained enabled and retained its access permissions, creating an exploitable attack vector.
Risk / Impact	Unauthorized access via inactive accounts; privilege misuse and violation of least privilege principle.
ISO 27001 Control	A.9.2.1 – User Registration and De-registration
Root Cause	Inactive accounts were not disabled or removed during user offboarding or account review processes.
Remediation Taken	Reviewed and identified inactive accounts. Disabled the 'ahmad-it' account while retaining it for audit and reference purposes.
Result	The inactive 'ahmad-it' account is now disabled and cannot be used for login, reducing the risk of unauthorized access.
Status	✓ RESOLVED

Finding 23: Lack of Activity Logs for Employees

Domain	Logging & Monitoring
Risk Level	● Medium
Description	No audit policies were configured, meaning employee activities were not logged or tracked, making it impossible to detect malicious or unauthorized actions.
Risk / Impact	Malicious or unauthorized actions go undetected; difficulty in incident investigation and lack of accountability.
ISO 27001 Control	A.8.15 – Logging
Root Cause	Audit policies were not configured to log system events and user activities in the Local Security Policy.
Remediation Taken	Enabled audit policies for all important events (account logon, account management, directory service access, logon events, object access, policy change, privilege use, process tracking, system events). Configured Success and Failure logging.

Result	All important events are now logged. Employee activities are tracked, enabling identification of malicious or unauthorized actions and supporting accountability.
Status	✓ RESOLVED

Finding 24: Mail Server Open Access

Domain	Access Control
Risk Level	• High
Description	The Mail_Server shared folder had 'Everyone: Full Control' sharing permissions, allowing unrestricted access to all network users.
Risk / Impact	Unauthorized access, modification, or exfiltration of sensitive mail server configuration data.
ISO 27001 Control	A.5.15 – Access Control
Root Cause	File sharing permissions were not configured to restrict access to authorized mail administrators only.
Remediation Taken	Removed 'Everyone' permission from the Mail_Server shared folder. Restricted access to 'Mail Admins Only' with appropriate read/write permissions.
Result	Mail_Server folder access is now limited to authorized Mail Administrators only. Unauthorized access has been eliminated.
Status	✓ RESOLVED

Finding 25: Open Shared File Storage Without Protection

Domain	Access Control
Risk Level	• High
Description	The shared file storage system was configured with 'Everyone: Full Control' permissions, allowing all users to access, modify, and delete files.
Risk / Impact	Unauthorized access to sensitive data, data modification, deletion, and loss of data confidentiality and integrity.
ISO 27001 Control	A.8.2.3 – Management of Privileged Access Rights
Root Cause	Shared folder was configured with open permissions allowing any user full control access.
Remediation Taken	Removed Everyone permissions from the shared folder. Restricted access to only authorized users or groups. Applied least privilege principle and reviewed both share and NTFS permissions.
Result	The shared file storage is now secured. Only authorized users or groups can access and modify files.
Status	✓ RESOLVED

Finding 26: Lack of Backup System for Sensitive Devices

Domain	Business Continuity
Risk Level	• High
Description	Devices containing sensitive information did not have an active backup system configured, leaving critical data vulnerable to permanent loss.

Risk / Impact	Loss of critical data due to system failure, malware, or human error; business disruption and inability to recover.
ISO 27001 Control	A.12.3.1 – Information Backup
Root Cause	Windows Backup had never been configured for devices containing sensitive organizational data.
Remediation Taken	Configured Windows Backup to an external hard drive (465.8 GB free of 931.5 GB). Verified backup settings and recommended a regular backup schedule with periodic restore testing.
Result	An active backup system is now in place. Critical data is protected and recoverable in case of data loss or system failure.
Status	✓ RESOLVED

Finding 27: Unprotected Network – Password Protected Sharing Disabled

Domain	Network Security
Risk Level	● Medium
Description	Password protected sharing was turned off, allowing backup files and shared resources on the network to be accessed without credentials.
Risk / Impact	Unauthorized access to network-shared files and printers; data exposure to unauthenticated users.
ISO 27001 Control	A.13.1 – Network Security Management
Root Cause	Advanced Sharing Settings had 'Turn off password protected sharing' selected, removing authentication requirements for network shares.
Remediation Taken	Enabled 'Turn on password protected sharing' in Advanced Sharing Settings to require valid user credentials for network resource access.
Result	Network shares are now password-protected. Only authenticated users with valid accounts can access shared files and printers.
Status	✓ RESOLVED

Finding 28: Sensitive Files Without Proper Permissions

Domain	Access Control
Risk Level	● Medium
Description	Critical files had improper NTFS access permissions, allowing unauthorized users to access or potentially compromise sensitive information.
Risk / Impact	Unauthorized access, data leakage, modification of sensitive files, and compromise of confidentiality and integrity.
ISO 27001 Control	A.5.15 – Access Control
Root Cause	NTFS permissions were not reviewed or configured to restrict access to authorized accounts only.
Remediation Taken	Reviewed and corrected NTFS permissions by restricting access to authorized accounts only (SYSTEM, Administrators, approved user accounts). Revoked excessive permissions from unauthorized accounts.
Result	File permissions are now properly configured. Sensitive files are accessible only to authorized accounts, enforcing data confidentiality and integrity.
Status	✓ RESOLVED

4.2 Open Findings – Action Required (2 of 30)

Finding 29: No Data Encryption for Customer Data

Domain	Cryptography
Risk Level	• High
Description	Customer data stored in the Mail_Server folder is not encrypted. The 'Encrypt contents to secure data' option is not enabled, leaving data vulnerable to unauthorized access and breaches.
Risk / Impact	High risk of data exposure, unauthorized access to customer data, and non-compliance with ISO 27001 cryptographic control requirements.
ISO 27001 Control	A.10.1.1 – Cryptographic Controls
Recommendation	Enable 'Encrypt contents to secure data' in Advanced Attributes for all folders containing customer data. Enforce BitLocker for full disk encryption. Implement encryption at the application and database level for sensitive data. Regularly review encryption settings and monitor compliance.
Status	✗ OPEN – ACTION REQUIRED

Finding 30: Admin Account With Unrestricted Privileges

Domain	Access Control
Risk Level	• High
Description	Multiple accounts (Admin, Administrator, user1) are members of the local Administrators group, providing unrestricted access to all system resources without appropriate oversight or restriction.
Risk / Impact	High risk of privilege abuse, unauthorized system changes, malware execution, data breach, and full system compromise.
ISO 27001 Control	A.9.2.3 – Management of Privileged Access Rights
Recommendation	Apply the principle of least privilege. Use separate admin accounts for administrative tasks only. Remove unnecessary accounts from the Administrators group. Use standard user accounts for daily activities. Enable UAC at the highest level. Implement RBAC. Enable logging and monitoring for administrative actions. Enforce MFA for admin accounts.
Status	✗ OPEN – ACTION REQUIRED

5. Recommendations & Remediation Roadmap

5.1 Immediate Actions (High Risk Findings)

- Finding 29: Enable EFS encryption and BitLocker for all folders containing customer data. Implement encryption at application level.
- Finding 30: Remove redundant administrator accounts. Enforce principle of least privilege. Implement Role-Based Access Control (RBAC) and Multi-Factor Authentication (MFA) for all privileged accounts.

5.2 Strategic Security Recommendations

- Upgrade from Windows 10 to a supported OS version to ensure continued receipt of security patches and compliance with vendor support timelines.
- Implement a centralized Identity and Access Management (IAM) solution to enforce consistent access policies across all devices and accounts.
- Deploy a Security Information and Event Management (SIEM) solution to centralize audit log collection, correlation, and alerting for security incidents.
- Establish a formal Patch Management Process with defined SLAs for critical, high, and medium patches aligned to ISO 27001 A.12.6.1.
- Implement a Data Loss Prevention (DLP) solution to monitor and prevent unauthorized data transfers via USB, email, and cloud services.
- Conduct regular security awareness training for all employees covering password hygiene, phishing, and acceptable use policies.
- Establish a formal Backup and Recovery Testing schedule, including quarterly restore tests for all critical systems and data.
- Perform periodic Access Rights Reviews (at least quarterly) to identify and revoke unnecessary permissions in line with A.9.2.5.

5.3 Compliance Roadmap

Priority	Action Item	Timeline	ISO Control
Critical	Encrypt all customer data (EFS + BitLocker)	Immediate	A.10.1.1
Critical	Reduce admin account privileges (RBAC + MFA)	Immediate	A.9.2.3
High	OS upgrade planning from Windows 10	30 Days	A.12.6.1
High	Deploy SIEM for centralized log monitoring	60 Days	A.12.4.1
Medium	Implement formal patch management process	60 Days	A.12.6.1
Medium	Establish DLP controls	90 Days	A.8.12
Low	Security awareness training program	90 Days	A.7.2.2
Low	Quarterly access rights review process	Ongoing	A.9.2.5

6. Conclusion

This GRC Security Assessment successfully identified, analyzed, and remediated 28 of 30 security findings within the Windows 10 environment. The assessment was conducted by Fares Khzouz in strict alignment with ISO/IEC 27001:2013 information security management standards.

The remediation actions taken have significantly improved the security posture of the assessed environment. Key improvements achieved include:

- Strengthened access control across user accounts, shared folders, and administrative privileges
- Enabled encryption at rest (EFS, BitLocker) and in transit (128-bit file sharing encryption)
- Restored and verified firewall, anti-malware, and automatic update protections
- Implemented comprehensive audit logging and employee activity monitoring
- Eliminated USB storage risks, open RDP access, and plain-text credential storage
- Configured account lockout policy to prevent brute-force attacks
- Established backup systems for critical data protection and recovery

Two findings (Finding 29: No Data Encryption for Customer Data, and Finding 30: Admin Account With Unrestricted Privileges) remain open and require immediate attention. Detailed recommendations have been provided in Section 5 to guide the remediation of these outstanding items.

It is recommended that the organization conduct a follow-up assessment within 90 days to verify closure of all open findings, validate the effectiveness of implemented controls, and ensure continued alignment with ISO 27001 requirements.

Document Sign-Off

Role	Name	Date
Assessor / Author	Fares Khzouz	May 15, 2025
Reviewed By		
Approved By		